

DIB: Managing Local MUD Policy Lifecycles with Shared IoT Traffic Evidence

Anonymous Authors

Abstract—Shared IoT traffic observations can help administrators create Manufacturer Usage Description (MUD) policies when manufacturer profiles are unavailable or outdated. Their lifecycle requires coordinated withdrawal while preserving local control over permissions. This paper presents Device Intent Blueprint (DIB), a framework that separates shared traffic evidence from local authorization. Candidate communications enter a review queue and generate MUD rules only after local approval. A shared dispute invalidates approvals, while restoration requires renewed review and preserves independent local revocations. DIB records approval validity and revocation origin, allowing disconnected sites to reconcile even after missing an entire withdrawal and restoration episode. Exhaustive exploration of finite lifecycle models finds no property violations, and six guard-removal mutations expose distinct authorization failures. An OpenWrt/osMUD testbed demonstrates rule application and withdrawal. Disconnected sites reconcile through a single collapsed update; the reconciliation logic takes under 100 ms in the evaluated deployment. Experiments on three IoT traffic datasets characterize candidate selection separately from authorization. Threshold admission restricts candidates under a bounded malicious-share assumption, while score-based ordering prioritizes review. Ranking the pooled candidate set achieves comparable review yield at matched budgets. These results support configurable candidate selection within a lifecycle that preserves local decisions during coordinated recovery.

Index Terms—IoT security, Manufacturer Usage Description, distributed network management, access policy management, policy lifecycle.

I. INTRODUCTION

Internet-of-Things (IoT) devices rely on network services for updates, remote control, and data exchange. Restricting their communications to the services they need can limit their exposure and the network activity of compromised devices [1], [9]. To support this approach, the Internet Engineering Task Force (IETF) standardized Manufacturer Usage Description (MUD) [2]. A MUD file describes a device’s intended communications. A MUD manager translates this description into access-control rules for the local network.

Manufacturer profiles may be unavailable or become outdated as firmware and cloud services change [9], [29]. Traffic observations can help administrators draft or update these profiles. Reports from other networks provide additional evidence when local observations are still limited. However, a service used in one network may be unnecessary in another, and observed traffic may include communications generated by compromised devices [1], [29]. Administrators must therefore decide which proposed rules to apply in their own networks.

This decision is part of a policy lifecycle. Consider a camera without a manufacturer profile: two networks observe the

same cloud service, and an administrator uses their reports to approve a local rule. If a contributor later disputes that service, the participating networks must withdraw the associated permissions. Once the dispute is resolved, the system must distinguish dispute-induced withdrawal from independent local revocation. It must preserve this distinction when reconciling a network that was disconnected throughout the episode.

This paper proposes *Device Intent Blueprint (DIB)*, a framework for managing locally authorized MUD policies from shared IoT traffic observations. We call each independently administered network a *site*. DIB groups observations into *endpoint facts*, each identifying a device type, communication direction, protocol, peer, and port. The observations and contributor reports supporting a fact form its *evidence*, and a *registry* stores that evidence alongside separate records of each site’s policy decisions.

DIB separates candidate selection from authorization. Selected facts enter MonitorOnly, where administrators review them without creating MUD rules. Local approval moves a fact to Active for export. A shared dispute invalidates approvals; restoration requires renewed review and preserves local revocations. Ordered updates reconcile sites that missed intermediate changes.

Existing approaches cover profile extraction, evidence sharing, and coordinated authorization (Table I). DIB addresses recovery across independent authorities by combining deny-overrides and a last-writer-wins pending register with explicit approval validity and revocation origin. Together, these records determine whether a recovering site must return a fact to review or retain an independent local veto.

The main contributions are: (1) a policy lifecycle and reconciliation mechanism that preserve local authorization during shared withdrawal and recovery, including after missed episodes; (2) a registry and distributed prototype, evaluated through finite-state verification, controlled ablations, recovery experiments, and OpenWrt/osMUD enforcement; (3) a matched evaluation on three IoT traffic datasets that distinguishes the effects of candidate admission and review ordering.

The remainder of this paper is organized as follows. Section II reviews related work. Section III defines the setting and design goals. Section IV presents DIB. Sections V and VI describe the implementation and evaluation. Finally, Section VII discusses implications and limitations.

II. RELATED WORK

RFC 8520 leaves the local application of MUD recommendations to the network administrator and calls for policy

TABLE I
POSITIONING AGAINST THE CLOSEST RELATED SYSTEMS.
“DISCONNECTED”: WHAT HAPPENS TO A PARTICIPANT THAT MISSES A
WITHDRAWAL. “ORIGIN”: WHETHER SHARED RESTORATION
DISTINGUISHES DISPUTE-INDUCED REVOCATION FROM INDEPENDENT
LOCAL REVOCATION.

Approach	Authority	Propagated	Disconnected	Origin
MUD extraction [3], [5], [14]	single domain	none (no sharing)	n/a	n/a
Evidence sharing [13], [15], [16]	recipient	reports, models	unspecified	not modeled
FIDEM [31]	manufacturer	profile, URL updates	re-check on reconnect	n/a
POLARIS [32]	resource owner	bound sessions	session expiry	n/a
Zanzibar [33]	one global service	consistency tokens	blocks on staleness	single origin
DIB	each site	ordered lifecycle targets	stale grant voided	preserved

updates to respect deployment-specific approval flows [2, Secs. 1.1 and 1.8]. A parallel IETF effort standardizes MUD URL reissuance [34], which concerns authority over manufacturer-URL updates. DIB governs operator-approved facts derived from traffic observations. Prior work extracts or enforces profiles from local traffic within one administrative domain [3], [5]–[8], [14] rather than governing observations shared across domains.

Threat-intelligence sharing (MISP, STIX), contributor reputation [15]–[18], and collaborative IoT learning (CoLearn, DIoT, IoT Inspector) [11]–[13], [28] aggregate evidence, traffic models, or anomaly reports. These approaches share information rather than grant network access, and therefore specify no withdrawal semantics for permissions already installed at a recipient.

Policy-based management and intent frameworks address policy specification, conflicts, and configuration [19]–[24]. POLARIS lets resource owners decide access from verifiable attributes and binds access to sessions [32]. FIDEM verifies device–MUD-class binding and propagates profile updates through URL reissuance or signature-change checks [31]. Their workflows address identity-based access and profile authenticity, respectively. DIB assumes established identities and specifies how shared withdrawal invalidates per-site approvals, how restoration preserves local vetoes, and how sites reconcile after missed episodes. Dynamic and security-tested MUD profiles [10], [25] also motivate profile evolution.

The deny-overrides combining rule in XACML and policy frameworks [35], [36] resolves conflicting decisions during policy evaluation. DIB retains the origin of a revocation across updates so that a shared restore preserves a local denial. Zanzibar [33] addresses stale authorization through consistency tokens in a globally coordinated service, where one authority both grants and revokes. DIB propagates withdrawal to sites that grant permissions independently and reconciles unreachable sites after reconnection. Its pending target follows a last-writer-wins register [37], with local guards preserving revocation origin.

III. THREAT MODEL AND GOALS

We consider a closed consortium of independently administered networks, called sites. Members share observations about endpoint facts, while each site controls the rules installed at its gateway. We address the risk that shared updates reinstate a withdrawn permission or erase a local denial during recovery.

A. Setting and Trust Boundary

Deployment requires authenticated membership and role enforcement. One deployment option is mutual TLS with enterprise public-key infrastructure (PKI), binding each member certificate to a site identifier and its permitted API operations. Device-type labels must also be aligned before ingestion. The prototype does not validate this authentication integration; the experiments exercise the lifecycle with trusted caller identities. Admission further assumes that malicious contributors control at most a fraction f_s of the eligible reporting population for a device type (Sec. IV-C). Identity-inflation tests deliberately exceed this bound.

Policy authority. DIB produces locally authorized MUD files: the receiving site’s MUD manager signs these exports and the gateway trusts that site’s policy-signing authority. Peer sites and the shared evidence service can therefore request withdrawal but cannot issue local permissions. This trust configuration is a deployment requirement. The enforcement testbed uses unsigned exports with signature validation disabled.

We evaluate three distinct adversarial behaviors: (i) **A1 (Poisoned Observations)**, where an honest site captures and reports real malicious flows from an already compromised device; (ii) **A2 (Fabricated Evidence)**, where contributors report fabricated traffic that did not occur (bounded by breadth share f_s , or unbounded in Sybil stress tests); and (iii) **A3 (Low-and-Slow Behavioral Drift)**, where actual device activity changes gradually across sites to mimic a legitimate rollout. A2 tests invented reports; A3 tests the ambiguity of observed behavior.

Local operators authorize permissions within their own domain, so misuse of a local approval or revocation is an insider action. Remote contributors can introduce unsuitable candidates or raise baseless disputes, but neither creates local authorization. Under A3, legitimate and malicious activity with identical traffic patterns produce the same evidence and score, and separating them requires local review or out-of-band information.

Consortium authority. Any participating site can raise a dispute. The first report suspends export, and a report from a second distinct site confirms revocation. Global restoration is a privileged consortium operation; local approval, revocation, and restoration are reserved for the receiving site’s operator. Sec. VI-C evaluates the availability trade-off of one versus two reporters. The safety properties I1–I3 (Sec. IV-B) concern lifecycle transitions under authenticated identities: the prototype and finite model expose transitions to a trusted harness, so caller authentication and role enforcement are deployment assumptions rather than verified mechanisms.

B. Design Goals

DIB has four design goals:

- **G1 (Local authorization).** Export permissions only after approval by the receiving site’s administrator.
- **G2 (Candidate discovery).** Propose communications from shared observations when manufacturer profiles are unavailable.
- **G3 (Review workload).** Filter and prioritize candidates for administrator review.
- **G4 (Decision stability).** Evidence and score changes must not grant or revoke permissions; disputes and operator actions follow the lifecycle rules.

P5 (Conditional admission protection). With *raw breadth* (the unweighted fraction of eligible sites reporting a fact), admission rejects adversary-only evidence under the share bound in Sec. III-A and parameter constraint in Criterion 1. This does not establish benignity; Sec. VI-E1 evaluates its limits.

IV. PROPOSED APPROACH

DIB comprises a shared evidence service and independently administered site services (Fig. 1). The evidence service receives observations and distributes candidates and ordered lifecycle updates. Each site retains its decisions, operator interface, and MUD exporter. Its service applies shared updates, preserves local revocations, and exports approved facts to the MUD manager.

A. Records and Operational Flow

For device type d , an endpoint fact is $f = (d, e)$, where $e = (\text{direction}, \text{protocol}, \text{peer}, \text{port})$. The peer is a fully qualified domain name (FQDN) or remote IP address. Before scoring, adapters associate observed names with addresses and normalize protocol labels. Names come from DNS records or HTTP/TLS metadata, depending on the dataset; the remaining fields come from the flow’s direction, protocol, and port. Scoring uses outbound communications because the evaluated captures predominantly contain device-initiated traffic. The exporter can also generate return-flow entries.

The registry is the logical record model for shared evidence and per-site decisions. The single-registry implementation stores both in one service. In the distributed prototype, the shared evidence service holds only shared records; each site stores its own decisions (Sec. VI-B). Shared records contain observations, reporting sites, timestamps, and attestations. The contribute operation deduplicates submissions; attest records a positive site assessment. *Local* evidence fails admission; *Corroborated* evidence meets the endpoint, reporting-site, score, and dispute checks for review (Sec. IV-C). Three distinct positive attestations promote an undisputed Corroborated record to *Consortium-attested*. These labels establish neither benignity nor permission to communicate.

Site-local records hold decisions and their revision history. A QUERY stages an admissible fact as MonitorOnly if the site has no record, or returns its existing decision; it is therefore not a read-only operation. MonitorOnly places a proposal in

TABLE II
ILLUSTRATIVE RECORDS AND EXPORT FOR THE CAMERA EXAMPLE.
FIELD GROUPS SUMMARIZE STORED INFORMATION, NOT AN API
SERIALIZATION.

Record	Example contents
Endpoint fact Evidence	(camera, out, TCP, api.vendor.example, 443) Reporters A and B; observation timestamps and counts; computed admission score
Site A decision	Active after A’s commit; valid approval; commit event in decision history
Site B decision	MonitorOnly; no approval; no exported rule
Site A MUD ACE	Destination DNS name api.vendor.example; IP protocol 6; TCP destination port 443; forwarding accept

the operator’s review queue without generating a network rule. Local approval is recorded through OPERATOR-COMMIT (a local commit), the only operation that authorizes export. Decision history records lifecycle events and the resulting state, actor, time, and reason where supplied, allowing restoration to distinguish a local veto from shared withdrawal.

From observations to a MUD rule. For the camera example (Table II), two sites report TCP traffic to api.vendor.example on port 443. Once admitted, the fact enters site A’s review queue as MonitorOnly. An OPERATOR-COMMIT moves it to Active, and the exporter emits an access-control entry (ACE) matching the destination DNS name and TCP port in the from-device access-control list (ACL), which the MUD manager resolves and installs. Site B requires its own approval. Withdrawal regenerates the site’s policy, which the gateway must apply to remove installed permissions. Table III specifies the recovery transitions.

B. Site-Local Authority Lifecycle

Figure 2 summarizes the transitions. At each site s , an endpoint fact f resides in one of five authorization states:

$$S = \{\text{Absent}, \text{MonitorOnly}, \text{Active}, \text{Disputed}, \text{Revoked}\}.$$

Revoked (Dispute) and Revoked (Local) share state Revoked but differ in the separately stored revocation origin. Each local approval enters Active and creates a fresh *grant*, tracked by $\text{grantValid}[s][f]$. Export requires both:

$$\text{Exportable}(s, f) \iff \text{state}(s, f) = \text{Active} \wedge \text{grantValid}(s, f). \quad (1)$$

Table III gives the transitions and guards, which also depend on grant validity, dispute status, and revocation origin.

Review candidates are not permanent: a MonitorOnly record with no prior operator action returns to Absent once its evidence has stayed below admission for the retention window W , bounding queue growth without touching any record carrying a local decision. A local veto can be recorded from Active, MonitorOnly, Disputed, or dispute-derived Revoked. It changes only the receiving site’s record and survives dispute confirmation and global restoration. Local restore remains blocked while a shared dispute is open. Once the dispute is resolved, local restore returns the record to review; export requires a fresh local commit.

Core Invariants (I1–I3). Under the stated identity assumptions, the lifecycle requires:

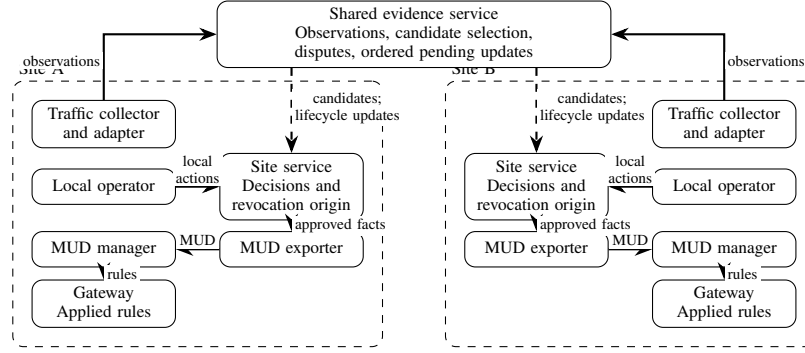


Fig. 1. DIB's distributed architecture. Dashed boxes delimit local administrative authority. Solid arrows carry observations, local decisions, and policy output; dashed arrows carry shared candidates and lifecycle updates, which disconnected sites retrieve on reconnection. The MUD manager and gateway may be co-located, as in the OpenWrt testbed.

TABLE III

LIFECYCLE TRANSITIONS. PARENTHETICAL LABELS ON REVOKED INDICATE REVOCATION ORIGIN; SLASHES SEPARATE ALTERNATIVE SOURCE STATES. REPEATED REPORTS FROM THE SAME SITE AND REPORTS AFTER CONFIRMED REVOCATION ADD NO TRANSITION. OTHER UNDEFINED TRANSITIONS ARE REJECTED OR LEAVE THE RECORD UNCHANGED. RETENTION EXPIRY IS SPECIFIED HERE BUT LIES OUTSIDE THE VERIFIED CONFIGURATION.

Current state	Event	Precondition	Next state	Grant valid?	Exportable?
Absent	query/stage	admitted; no open dispute	MonitorOnly	no	no
MonitorOnly	local commit	local operator; no dispute	Active	yes, new	yes
MonitorOnly/Active	first dispute	valid dispute	Disputed	no	no
Disputed	second dispute	distinct reporting site	Revoked (Dispute)	no	no
Disputed/Revoked (Dispute)	global restore	authorized restore	MonitorOnly	no	no
Active/MonitorOnly/Disputed/Revoked (Dispute)	local revoke	local operator	Revoked (Local)	no	no
Revoked (Local)	local restore	no open dispute	MonitorOnly	no	no
MonitorOnly	retention expiry	below admission for window W ; no local decision	Absent	no	no
Revoked (Local)	global restore	—	Revoked (Local)	no	no
Absent	dispute	—	Absent	no	no

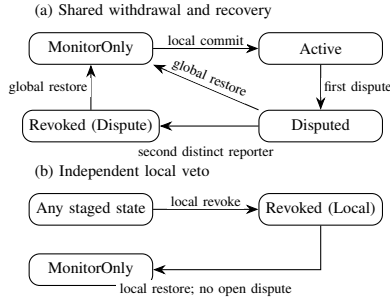


Fig. 2. Recovery paths for an admitted fact. A local veto can be recorded from MonitorOnly, Active, Disputed, or Revoked (Dispute), and survives global restore. Panel (a) shows withdrawal from Active; all guards are in Table III.

- **(I1) Fresh Local Authorization:** Only operator-commit by site s 's operator can move fact f into Active and create a valid grant at that site.
- **(I2) Site Confinement:** Local commit, revoke, and restore at site s leave every peer site's records unchanged.
- **(I3) Conservative Reversal:** A dispute invalidates grants and export eligibility at reachable sites during fan-out and at other sites upon reconciliation. Restoration requires fresh local approval and preserves independent local revocations, including those recorded at sites that missed the entire dispute/restore episode. No timing bound is imposed on reconciliation.

Export control. Equation 1 gates export on current local authorization, and verification checks that commit, dispute, restore, and reconciliation maintain it across their interleavings. The mutations in Table V isolate failures of grant coherence, site confinement, veto preservation, and export

TABLE IV

ADMISSION NOTATION AND OPERATING VALUES (d : DEVICE TYPE; e : ENDPOINT).

Symbol	Meaning	Value
ES_d	sites with ≥ 1 observation of device type d	—
$S_{d,e}$	subset of ES_d reporting endpoint (d, e)	—
C_s, C_t	cross-site breadth; temporal confidence	—
m	minimum reporting sites (quorum)	2
θ	admission threshold	0.65
α, β	breadth / temporal weight, $\alpha + \beta = 1$	0.6, 0.4
f_s	assumed adversarial breadth share	0.30

control. Gateway application follows export, so an unreachable gateway can retain an older policy until reconnection.

C. Candidate-Selection Policy

The prototype uses automatic admission to limit the proposals presented for local review. We define the admission rule, its score, and the component checks below. Table IV lists the parameters. The alternative selection policies evaluated in Section VI change the review queue while retaining the same local approval and recovery rules.

Combined rule. Automatic staging requires endpoint eligibility, at least m reporting sites, score at least θ , and no unresolved dispute. We use $m = 2$ to exclude single-site reports without a larger quorum's admission cost; distinct identities do not guarantee independent observations:

$$\begin{aligned} \text{admit}_{\text{auto}}(d, e) = & (A(d, e) = 1) \wedge (|S_{d,e}| \geq m) \\ & \wedge (\text{score}(d, e) \geq \theta) \\ & \wedge \neg \text{openDispute}(d, e). \end{aligned} \quad (2)$$

Passing permits staging, not export, and does not override existing local decisions (Sec. IV-A).

Admission score. With nonnegative weights α, β for breadth and temporal confidence,

$$\text{score}(d, e) = \alpha C_s(d, e) + \beta C_t(d, e), \quad \alpha + \beta = 1. \quad (3)$$

Eligibility. The endpoint filter sets $A(d, e) = 1$ for DNS, NTP, update, or vendor-cloud communications, using port, protocol, and name-substring rules. Vendor-cloud includes any remaining FQDN, while private, reserved, and link-local IP literals are excluded. The filter selects endpoint formats and service categories, so resolved attacker domains can also qualify.

Breadth and persistence. Breadth $C_s = |S_{d,e}|/|ES_d|$ measures the fraction of sites observing device type d that report endpoint e . Let $D_{d,e}$ contain the UTC observation dates of (d, e) across sites, and D_d the dates of all observations of d . With pooled observation counts $n_{d,e}$ and n_d , temporal confidence, used here as a measure of persistence, combines day coverage and relative frequency:

$$C_t = 0.7 \frac{|D_{d,e}|}{|D_d|} + 0.3 \frac{n_{d,e}}{n_d} \in [0, 1]. \quad (4)$$

The 0.7/0.3 split weights day coverage above pooled volume, reducing the influence of high traffic volume from a single reporter. Because $n_{d,e}/n_d$ is structurally small for device types with many endpoints, C_t is in practice dominated by day coverage. We hold this split fixed and sweep only θ and α (Sec. VI-E1).

We choose weights that reject facts reported exclusively by a bounded malicious minority, then measure the resulting coverage.

Criterion 1 (Admission design constraint). If malicious contributors hold at most breadth share f_s of the eligible population and an endpoint fact is reported only by them, then $C_s \leq f_s$ and $C_t \leq 1$, so

$$\text{score}(d, e) \leq \alpha f_s + \beta = 1 - \alpha(1 - f_s). \quad (5)$$

Requiring this upper bound to fall strictly below θ constrains the parameters to $\alpha > (1 - \theta)/(1 - f_s)$, equivalently $f_s < 1 - (1 - \theta)/\alpha$.

At $\theta = 0.65$ and $f_s = 0.30$ this requires $\alpha > 0.5$. Choosing $\alpha = 0.6$ gives an upper bound of 0.58 and rejects adversary-only evidence for raw-breadth shares below 5/12. Sec. VI-E1 evaluates coverage at alternative parameters.

Sybil-aware variants. Raw breadth counts identities, so fabricated ones inflate it. Trust weighting replaces C_s with

$$C_s^{\text{trust}} = \frac{\sum_{i \in S_{d,e}} w_i}{\sum_{i \in ES_d} w_i}, \quad w_i = \min(1, b_i/b_{ref}),$$

Here, b_i counts site i 's distinct contributed facts across device types, and b_{ref} is their median in a frozen clean snapshot. Only b_{ref} is frozen, so current b_i includes new identities and padding. Clustering instead joins sites at Jaccard endpoint-set similarity ≥ 0.8 and computes breadth over the connected components. The registry and independent-deployment experiments use raw breadth, to which Criterion 1 applies.

Sec. VI-E1 compares all three under identity inflation. These variants rely on a clean reference or informative endpoint diversity and fall outside the raw-breadth bound.

V. IMPLEMENTATION AND EVALUATION METHOD

The distributed prototype separates shared evidence from site-local decisions into distinct services (Sec. VI-B). Registry transactions apply per-fact dispute/restore changes atomically, with up to ten retries for conflicting writes. The implementation uses Python and FastAPI, with SQLAlchemy 2 and SQLite for persistence.

To test whether lifecycle changes reach gateway enforcement, we run unmodified osMUD commit 852918e in a privileged Docker container with the OpenWrt 23.05.5 root filesystem. Restarting osMUD after each policy change applies MUD ACLs as nftables rules. We record ACEs, effective rules, registry/osMUD state, and a live TCP probe for each transition. Exports are unsigned and signature validation is disabled.

Candidate-selection experiments use three traffic datasets. UNSW-IoTraffic [4] supplies 27 device types and 28 traffic-derived reference profiles; its single capture is shuffled and partitioned round-robin into ten pseudo-sites (seed 42 unless stated). Mon(IoT)r [26] provides US and UK captures after collapsing VPN variants; YourThings [27] adds a third deployment for cross-lab comparisons (Sec. VI-D2). We retain device-initiated flows with a port and global peer or public name. UNSW associates IPs with same-site HTTP Host and TLS Server Name Indication (SNI) within 24 hours; Mon(IoT)r uses cumulative DNS.

Using these observations, we assess sharing by comparing receiver-only evidence (*local-only*) with all pooled facts (*pooled union*). Successively adding a two-reporter quorum, the score threshold, and endpoint eligibility isolates filtering effects, while *ranked union* selects the highest-scoring pooled facts at matched review budgets.

We then test robustness with captured and synthetic inputs. The A1 replay injects 165 malicious observations forming 59 endpoint facts at $k = 1, \dots, 10$ pseudo-sites, using *frequency filtering* ($n_{d,e} \geq 2$ pooled observations) as a baseline. Further tests inject fabrications, resolved-name and port masquerading, Sybil identities (200–3,200 over 20–400 days), and synthetic rollouts, with fabricated endpoint sets diversified by 0/10/25/50% of a baseline pool. For identity inflation, *reputation-weighted voting* (RWV) provides a comparison requiring weighted support above 0.65, with frozen pre-attack weights and weight 0.1 for unseen identities.

To measure agreement with reference behavior, we match predictions on device, direction, normalized protocol, peer, and port, treating port 0 and unknown protocol as wildcards and CIDR ranges by membership. Micro metrics pool true/false positives and negatives; UNSW macro metrics average over its 28 reference profiles. Aggregates use seeds 0–19, A1/Sybil/drift use seed 42, and cross-lab, OpenWrt, and concurrency use seed 0.

For reproducibility, the anonymized repository supplied with the submission contains configurations, input hashes, adapters, sampling details, generated MUD files, gateway states and

TABLE V
GUARD-REMOVAL MUTATIONS M1–M6 AND THEIR COUNTEREXAMPLES.
A SEPARATE CONTROL WITH OPERATOR-COMMIT DISABLED LEAVES
2,076,196 REACHABLE STATES, NONE ACTIVE.

ID	Property	Guard removed	Counterexample
M1	Grant coherence	restore recreates grant	authorization without commit
M2	I2 site confinement	cross-site commit	remote commit alters s'
M3	I2 local-revoke confinement	local-revoke fans out	remote site's record changes
M4	I3 global restore preserves local revoke	restore ignores revocation origin	local veto erased
M5	I3 local-restore conservative	local-restore ignores open dispute	site escapes live dispute
M6	Export requires Active	disputed export	ACE emitted while Disputed

probes, TLA+ specifications and logs, matched ablations, parameter and identity-inflation grids, and regression evidence. This pre-submission package is not an archived public release; a permanent DOI will be minted for the accepted artifact.

VI. EVALUATION

The experiments assess whether DIB preserves local authorization during shared withdrawal and recovery. Model checks and ablations examine the guards; gateway and outage tests demonstrate enforcement and reconciliation. We then measure management performance and candidate-selection effects on proposal volume and traffic agreement. The candidate counts quantify review volume; operator time and decision quality remain to be evaluated.

A. Authorization and Recovery

We first check whether lifecycle transitions preserve local authorization, then test the corresponding behavior in the registry and at the gateway. The TLA+ model represents three sites and two facts, distinguishing the dispute opener, confirmer, and bystander. Exhaustive exploration of 4,311,852 reachable states finds no violation of I1–I3 or the export checks: only local commits create fresh authorization, export requires it, and disputes invalidate it without affecting unrelated facts. The model checks site confinement (I2) for the single-registry implementation; in the distributed prototype, each site owns its store.

A distributed model adds disconnection at one of three sites, with one fact and local revoke and restore enabled while the site is unreachable. It explores 48,960 distinct states to depth 18 without violations. Both checks are exhaustive only within their finite configurations; they do not cover gateway timing, authentication, or distributed linearizability.

To identify which safeguards prevent failures, we remove six lifecycle guards in separate model variants, labeled M1–M6. Each produces a distinct authorization failure involving grant handling, site confinement, revocation origin, or export control (Table V).

The registry tests exercise these rules through one- and two-dispute episodes, repeated restoration, and local vetoes recorded before or during withdrawal. Across these tests, the

TABLE VI
RESTORATION-POLICY ABLATION: SIX SEQUENCES PER POLICY, THREE SITES, TWO FACTS, COUNTED AFTER RESTORE/RECONCILIATION AND BEFORE FRESH COMMITS. ALTERNATIVES ARE CONTROLLED ADAPTERS OVER THE SAME IMPLEMENTATION.

Restoration rule	Subject without commit	ACEs new	Local vetoes preserved
Reuse approval; preserve veto	12/18		6/6
Reset every record to review	0/18		0/6
Provenance-aware review (DIB)	0/18		6/6

registry preserves local vetoes, blocks local restore during an open dispute, and requires a fresh commit after restoration.

To isolate the effect of restoration policy, three sites approve a test fact and an unrelated control fact. Six event sequences place a local veto before a dispute, during suspension, or after confirmation, with all updates delivered or another site missing the episode. Reusing approvals exports the test fact at both non-vetoing sites after every sequence. Resetting all records to review prevents export but erases all six vetoes. Among the three policies, only DIB prevents export of the test fact while preserving every veto (Table VI). All three policies preserve the control fact and ignore stale replay, isolating the difference to restoration handling.

Evidence updates are tested separately from lifecycle events (G4). With the same fact in Active, MonitorOnly, and locally Revoked states at three respective sites, repeated score changes leave decision states, authority records, and MUD export unchanged. Only Active records receive a review flag, with the change recorded in the audit history. This result comes from registry tests, since the finite model represents admission only as a Boolean.

Finally, all ten gateway cases show that osMUD applies the exported policies as expected. MonitorOnly produces no rule; a local commit permits the tested FQDN on TCP/8080 and UDP/5353. The first dispute removes both nftables rules and the live TCP probe is refused; a second dispute report confirms revocation. Global restore returns the record to review, and access resumes only after a fresh commit. Local revoke also removes the rules, while local restore alone leaves access blocked. Seven reversal cycles affect only the named fact, and the distributed services reproduce these transitions.

B. Management-Path Feasibility and Reconciliation

The registry measurements characterize both typical latency and delays under contention. On a 16-core x86_64 Linux host running Python 3.10.13, each of 1/10/50/100 writers performs 20 mixed operations after the same warm-up procedure. At 100 writers, throughput reaches 317.5 ± 10.8 operations/s and median latency is 3.8 ± 0.2 ms (mean $\pm$ sample SD over three repetitions), but p99 approaches 5.9 s. Instrumentation attributes this tail to SQLite's single serialized writer rather than lifecycle logic. All 9,660 timed operations complete without unexpected errors.

Separate concurrency checks cover nine correctness scenarios with 200 trials each and a retry-contention scenario with 25 trials and 25 writers. Across these 1,825 trials, the exercised interleavings produce no violations of the idempotency,

dispute-exactness, local-revoke-race, site-isolation, or audit-history checks.

The distributed configuration places decisions in ten independent site services while an evidence service holds shared scores and dispute/restore transitions. Each site enforces revocation origin locally. Dispute-open, confirming-dispute, and restore events fan out synchronously, with up to three attempts of 1 s each. Including this fan-out, the ten-site HTTP deployment sustains 530.3 operations/s at 100 writers, with p99 near 455 ms over five repetitions of 2,000 operations and no unexpected errors. All services run in separate processes on the same host.

Throughput gains from process separation do not increase monotonically with the number of sites. A controlled sweep varies site containers N while keeping stack, transport, operation mix, and hardware fixed, with $N = 1$ as the single-site control. At 100 writers, throughput is 320.9 operations/s for $N = 1$ and 557.7, 539.5, and 523.1 operations/s for $N = 2, 5,$ and 10 (means of five repetitions); the shared evidence service limits further gains. With one writer, fan-out instead reduces throughput from 125.7 to 99.8 operations/s, making ten sites 20.6% slower than one. Six of 64,400 timed requests fail on pooled client connections (0.0093%, no server 5xx); the reported counts include these failures and expected HTTP conflicts.

When a site becomes unreachable, the service retains only its latest pending target for each fact rather than every missed update. Reconnection applies that target through the same idempotent path, using a monotonic per-fact sequence number. A restore target therefore invalidates an old Active approval even if the preceding dispute never reached the site. Container stops simulate disconnection; WAN latency, packet loss, and asymmetric partitions remain outside this evaluation.

All 40 outage trials converge after reconnection through one collapsed pending record. Missing one event type—dispute-open, confirming-dispute, or restore—leads to convergence in 0.51 ± 0.03 s over 30 trials. Missing an entire dispute/confirmation/restore episode invalidates the stale approval through the final MonitorOnly target in 0.50 ± 0.04 s over ten trials (mean $\pm$ sample SD). Another 20 trials exercise races with new fan-out events and check that sequence numbers preserve the current target. Process restart (~ 0.45 s) accounts for most of the recovery time; reconciliation logic takes less than 0.1 s.

The same mechanism must preserve a local veto while invalidating a stale approval. Ten further trials use three site processes and one evidence process over loopback HTTP with persistent SQLite stores. Each site approves three facts; the target site locally revokes one and is stopped. Dispute/confirmation/restore episodes then complete for that fact and a second, Active fact. On restart, one collapsed restore target per fact preserves the veto and returns the stale Active fact to MonitorOnly in every trial. Neither is exported, while the unrelated fact remains Active and exportable at every site. Repeated reconciliation and replay of stale updates leave the records unchanged; direct commit cannot override the veto, and export of the locally revoked fact resumes only after local restore and a fresh commit.

C. Suspension Policy and Availability

With immediate suspension, 100 requests from one member withdraw 100 facts in 11.3 s across ten sites. This invalidates 1,000 authorizations and takes exports from 100 ACEs to zero per site, while concurrent read throughput remains at 85% of its initial value (432.3 to 366.0 operations/s; p99 30.6 to 39.0 ms). Recovery costs 11 requests per fact and 21.6 s: policy withdrawal disrupts access even though the service continues to process requests.

A deterministic API campaign compares suspension after one or two distinct reporters, with 100 approved facts per site. Under two-reporter suspension the first report is retained and the second opens the dispute: one reporter removes all 100 ACEs per site under immediate suspension and none under two-reporter suspension, while a second removes them under both. Duplicate reports add no votes, restoration clears report history, and in each configuration the 100 local vetoes recorded during withdrawal survive restoration with fresh commits required for export. Other experiments and the formal models use immediate suspension.

D. Candidate Selection on Captured Traffic

The captured-traffic experiments measure both coverage of observed behavior and the number of candidates presented for review.

In UNSW, only 55 of the 564 reference ACEs across 28 profiles remain observable after address filtering; 61 to-device entries cannot appear in device-initiated input. DIB stages 36 of the observable ACEs, retaining 65.5% of observable behavior but only 6.4% of the complete reference. Macro recall is 0.079, compared with 0.124 for observable behavior. Pooling still helps at cold start: after 30 days, pooling ten pseudo-sites yields a macro agreement F1 of 0.112 ± 0.002 , against 0.022 ± 0.005 for local-only monitoring of one pseudo-site (G2).

This gain reflects a larger sample, not agreement across independent networks. The pseudo-sites are round-robin shards of one capture and share device instances, firmware, and a DNS/CDN view. Every quorum $m \in \{2, \dots, 10\}$ admits the same 346 facts because of that partition. This experiment uses trust weighting; the independent-deployment comparisons that follow use raw breadth.

1) *Candidate Review Volume*: The independent Mon(IoT)r US and UK captures reveal how successive filters reduce proposal volume. After collapsing VPN variants, they share 26 device types with mean endpoint-fact overlap 0.25; three types share no facts. Both deployments contribute evidence in this experiment, unlike the held-out-receiver comparison that follows.

Of 24,886 distinct pooled facts, 24,046 occur at only one site and 840 at both, so the two-site quorum produces the largest reduction. The score threshold narrows the queue to 697 facts and endpoint eligibility to 462 (452 serializable): 98.1% fewer than pooling, 45.0% fewer than quorum alone, and 33.7% fewer than quorum with scoring. Across 32 daily windows, arrivals average 15.9 additions per site-day and peak at 432. These filters govern proposals only; Active facts that

TABLE VII

MATCHED COLD-START ABLATION: EACH RECEIVER USES THE OTHER TWO DEPLOYMENTS AS SOURCES. Q=TWO-SITE QUORUM; S=RAW-BREADTH SCORE; C=ENDPOINT ELIGIBILITY; N=CANDIDATES; COV.=DEVICE COVERAGE; P/R/F1=MACRO AGREEMENT WITH RECEIVER TRAFFIC OVER SIX DEVICE TYPES. FULL-DIB 95% F1 CIs (US/UK/YT): [.033,.198]/[.044,.186]/[.116,.384].

Receiver	Filter	N	Cov.	P	R	F1
US	Union	1005	100%	.322	.358	.327
	Q	42	83.3%	.750	.079	.139
	QS	40	83.3%	.750	.076	.135
	DIB (QSC)	36	83.3%	.750	.065	.116
UK	Union	767	100%	.279	.449	.320
	Q, QS	48	83.3%	.745	.078	.138
	DIB (QSC)	43	83.3%	.784	.064	.115
YT	Union	1387	100%	.059	.334	.095
	Q	177	100%	.173	.282	.208
	QS	146	100%	.257	.282	.268
	DIB (QSC)	107	100%	.286	.223	.247

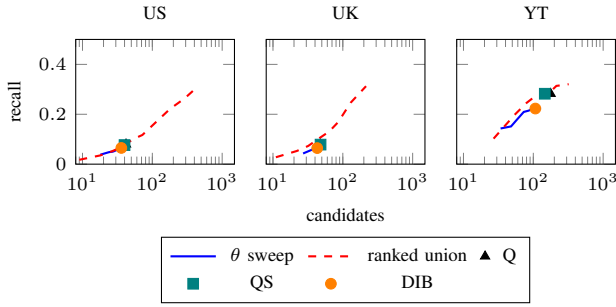


Fig. 3. Candidate count and macro recall for cold-start receivers. Solid curves vary $\theta \in [0.50, 0.80]$ at $m = 2$; dashed curves rank the pooled union by score at increasing budgets.

later fail admission remain authorized and receive a review flag.

2) *Proposals for a New Receiving Site*: A new receiving site presents a different constraint: its observations must not help select its own proposals. We exclude the receiver from reporter sets, eligible populations, days, and observation counts. Holding out either US or UK from this two-deployment comparison leaves only one source, which cannot satisfy $m = 2$. YourThings (YT) [27], an independent historical deployment with one day and 40 packet captures, supplies the third deployment. A fixed six-entry label mapping aligns the device types present in all three.

Each receiver then uses the other two deployments as sources, with identical observations and device scope across filters (Table VII). Precision, recall, and F1 (P/R/F1) measure macro per-device agreement with receiver-observed endpoints, and coverage is the fraction of the six types receiving a proposal. Scored rows use raw breadth with $\alpha = 0.6$, $\beta = 0.4$, and $\theta = 0.65$. Removing receiver observations leaves candidate sets unchanged, confirming that selection does not use them.

DIB reduces candidate counts by 96.4% at US, 94.4% at UK, and 92.3% at YT, but this reduction sacrifices coverage. The full union contains more receiver-observed endpoints—184/178/49 among 1005/767/1387 candidates—and achieves higher macro F1 at US/UK. It also requires 5.46/4.31/28.31 inspected entries per receiver-observed endpoint, compared with DIB’s 1.03/1.16/2.89. At the smaller DIB budgets, unranked union yields only an expected 6.6/10.0/3.8 matching

endpoints.

Ordering alone nevertheless recovers much of the review yield. At DIB’s budgets of 36/43/107 candidates, ranking the full union yields 35/39/40 receiver-observed endpoints, compared with DIB’s 35/37/37. The ranked prefixes overlap DIB’s queues by 86.9–90.7%; the additional matching endpoints at UK and YT pass quorum and score but fail endpoint eligibility. Quorum supplies most of the reduction at US/UK, yielding 35.1/36.7 matching endpoints at the DIB budgets. At YT, yield rises from 24.8 with quorum to 30.0 with quorum and score and 37.0 with the full rule.

Admission and ordering thus serve different purposes: ranking limits review to a budget, whereas admission excludes adversary-only evidence under Criterion 1. We recommend *threshold-then-rank* when that condition holds, reviewing a score-ordered prefix of the admitted queue when the budget is smaller than the queue. Figure 3 distinguishes these choices: solid curves vary the admission threshold and show its effect on queue size and recall; dashed curves rank the full union at increasing budgets. The solid curves do not evaluate prefixes of a fixed admitted queue.

These comparisons describe filter behavior on the selected captures, not a ranking of receiving environments. Observation windows and endpoint-set sizes differ, and only six device types are common to all three deployments. Their 95% F1 intervals (Table VII), computed by percentile bootstrap over those six types (1,000 resamples, seed 42), overlap across receivers. Restricting US and UK to their busiest days gives macro F1 0.241/0.213/0.258, further illustrating sensitivity to the observation window.

E. Adversarial Observations and Fabricated Evidence

Captured malicious traffic and fabricated reports challenge admission in different ways. We inject both into the ten UNSW pseudo-sites, whose partition fixes the reporting population and lets us control the malicious share f_s in Criterion 1. This setup does not establish reporter independence in a real consortium; that remains a governance assumption (Sec. III-A). The tests include 59 captured A1 facts at $k = 1, \dots, 10$ pseudo-sites, resolved-name and port-masquerading fabrications, and A2 across 20 seeds and malicious-site fractions $\{.05, .1, .2, .3, .4, .5\}$, realized by uniformly sampling the rounded pseudo-site count.

DIB stages none of the 59 captured A1 facts, whereas pooled union and frequency filtering stage all of them. The five annotation logs contain 354 raw captured packets, all with IP-literal destinations. The A1 replay retains the 165 device-originated packets with recognized transport protocols, which collapse to the 59 endpoint facts used in the method. Replacing the captured IP with a resolvable name, while keeping devices, sites, and timing fixed, raises admission from 0/150 to 21/150 configurations: five device types, $k = 1, \dots, 10$ reporting sites, and spread windows of 1, 30, or 120 days. The first admission occurs at $k = 7$ sites over 120 days (score 0.679). The filter therefore rejects the unresolved infrastructure in this capture, not malicious behavior in general; traffic to a resolved attacker domain can still enter review.

Port masquerading exposes the same distinction. With other inputs fixed, ports 53/123 pass endpoint eligibility while the port-443 control fails. At a one-day horizon, this counterfactual and the bounded-A2 tests share a maximum score of 0.354; extending fabrication to 120 days exceeds that value. At $f_s = 0.30$, the largest score passing quorum is 0.562 over 120 days, still below θ and consistent with the analytical bound of 0.58. At $f_s = 0.50$, outside the assumed bound, a 30-day fabrication reaches 0.663 and enters MonitorOnly. Thus, failure of admission filtering creates a false proposal, not permission to communicate.

1) *Parameter Sensitivity, Identity Inflation, and Drift:* The operating point chosen from the adversarial bound is not the one that maximizes traffic agreement. Sweeping $\theta \in [0.50, 0.80]$ and $\alpha \in [0.4, 0.9]$ on Mon(IoT)r yields a best macro F1 of 0.071, compared with 0.054 at the chosen setting. Figure 3 reports the separate cold-start threshold sweep at fixed $m = 2$.

Identity inflation deliberately violates the malicious-share assumption. The test grid uses 200–3,200 fabricated identities over 20–400 days, diversifying endpoint sets by 0–50% of a baseline pool. Raw counting admits the fabrication in 45 of 48 representative configurations. Trust weighting and clustering reject those configurations, while RWV admits all 48 at its fixed operating point. That protection is not universal: padding fabricated identities with real endpoints defeats clustering in the extreme configuration (score 0.905), and no tested Jaccard threshold in $[0.6, 0.95]$ withstands every padding level.

Even without identity inflation, traffic evidence cannot distinguish intentions that produce the same observations. A synthetic rollout over 27 device types varies adoption $p \in \{.2, .4, .5, .6, .8, 1\}$ and duration $D \in \{1, 7, 30, 120\}$ days within a 120-day horizon. Each duration is evaluated for all $27 \times 6 = 162$ device-type/adoption pairs; at $D = 120$ days, 69 pairs enter review. Separately, a time-to-admission sweep extends the same rollout through checkpoints at 1, 3, 7, 14, 30, 60, 90, and 120 days; among the 69 pairs admitted by day 120, the median first-admission checkpoint is seven days. Labeling the same injected endpoint as either legitimate change or compromise produces identical scores. Existing Active facts remain authorized and receive only a review flag. A rollout and a slow compromise with identical endpoints and cadence therefore require operator review or out-of-band investigation to distinguish them.

VII. DISCUSSION

Recovery depends on preserving approval validity and revocation origin, not on a particular representation of that information. The mutations (Table V) and restoration-policy ablation (Table VI) expose failures when either the information or its checks are omitted; implementations may retain it through states or history. Whether the resulting review process is practical still requires evaluation with operators.

Candidate selection can adapt to that review process without changing local authorization or recovery. Quorum accounts for most of the queue reduction at US/UK, while ordering explains the advantage over unranked pooling. These results support

threshold-then-rank where governance maintains the bounded-share assumption. Trust weighting and clustering mitigate identity inflation in the tested cases but fail under padding, so P5 does not apply without the bounded-share assumption. Ranking the union achieves slightly higher review yield at matched budgets, but no tested policy establishes benignity or policy necessity. Review capacity should also inform the retention window W , whose practical value remains to be determined.

Local control does not eliminate the availability costs of shared withdrawal. Immediate suspension lets one member interrupt service; requiring two reporters preserves permissions until corroboration but delays withdrawal if no second report arrives. Both policies remain vulnerable to collusion, and the prototype has no dispute rate limit or reputation penalty. Moreover, an unreachable gateway can retain a stale rule until reconnection: no withdrawal deadline is established here. Operators therefore need visibility into pending updates and installed policies. Rule leases could bound stale permissions at an additional availability cost.

These costs also depend on the reliability of the shared evidence service, which is both a throughput bottleneck and a single point of failure for candidate flow and withdrawal propagation. It holds no local authorization state: its failure can delay withdrawal but does not itself grant or revoke permissions at a site. Replication and recovery of this service remain deployment concerns. The co-located experiments do not evaluate WAN behavior or production workloads, while finite models assume authenticated callers and gateway tests disable signature validation. Deployment still requires the authentication, roles, and signing integration specified in Sec. III-A.

The evidence available to a deployment imposes further limits. The pseudo-site partition and six-type alignment restrict generalization, and the historical captures expose names through DNS or HTTP/TLS metadata. Encrypted Client Hello protects the inner server name, and encrypted DNS removes another source of name-to-address associations [38]; QUIC carries the TLS handshake in QUIC frames [39]. Coverage of fleets using these mechanisms has not been established for the evaluated adapters. Resolver-side telemetry or endpoint instrumentation could supply missing names without changing the approval and recovery rules applied to the resulting facts.

Policy output is similarly scoped: the exporter emits resolved-name TCP/UDP ACEs, not the TLS/DTLS profile parameters added by RFC 9761 [30]. If a manufacturer profile later becomes available, it remains separate from locally approved facts, with the MUD manager combining the sources under deny-overrides. Reconciling them with authorized MUD-URL updates [34] remains future work.

VIII. CONCLUSION

This paper presented DIB for managing locally authorized MUD policies from shared IoT observations. Finite-model checks and guard-removal mutations assess its authorization lifecycle; OpenWrt/osMUD tests demonstrate enforcement. Outage experiments show that one collapsed update preserves

local vetoes and invalidates stale approvals after a missed withdrawal and restoration episode. Candidate-selection and suspension experiments quantify review volume and availability costs. Future work will evaluate operator review, mechanisms to bound gateway withdrawal time, and recovery of the shared evidence service.

REFERENCES

- [1] M. Antonakakis *et al.*, “Understanding the Mirai Botnet,” in *Proc. 26th USENIX Security Symp.*, 2017.
- [2] E. Lear, R. Droms, and D. Romascanu, “Manufacturer Usage Description Specification,” RFC 8520, IETF, Mar. 2019.
- [3] A. Hamza, D. Ranathunga, H. Habibi Gharakheili, M. Roughan, and V. Sivaraman, “Clear as MUD: Generating, Validating and Applying IoT Behavioral Profiles,” in *Proc. ACM SIGCOMM Workshop IoT S&P*, 2018.
- [4] A. Sivanathan *et al.*, “Classifying IoT Devices in Smart Environments Using Network Traffic Characteristics,” *IEEE Trans. Mobile Comput.*, vol. 18, no. 8, pp. 1745–1759, 2019.
- [5] A. Hamza *et al.*, “Verifying and Monitoring IoTs Network Behavior Using MUD Profiles,” *IEEE Trans. Dependable Secure Comput.*, vol. 19, no. 1, pp. 1–18, 2022.
- [6] A. Hamza, H. Habibi Gharakheili, T. A. Benson, and V. Sivaraman, “Detecting Volumetric Attacks on IoT Devices via SDN-Based Monitoring of MUD Activity,” in *Proc. ACM SOSR*, 2019.
- [7] F. Corno and L. Mannella, “A Gateway-based MUD Architecture to Enhance Smart Home Security,” in *Proc. SpliTech*, 2023, pp. 1–6.
- [8] osMUD Project, “osMUD: Open Source MUD Manager,” <https://osmud.org>. (Accessed Jul. 24, 2026.)
- [9] J. L. Hernández-Ramos, S. N. Matheu, A. Feraudo, G. Baldini, J. Bernal Bernabe, P. Yadav, A. Skarmeta, and P. Bellavista, “Defining the Behavior of IoT Devices Through the MUD Standard: Review, Challenges, and Research Directions,” *IEEE Access*, vol. 9, pp. 126265–126285, 2021.
- [10] S. N. Matheu, J. L. Hernández-Ramos, S. Pérez, and A. F. Skarmeta, “Extending MUD Profiles Through an Automated IoT Security Testing Methodology,” *IEEE Access*, vol. 7, pp. 149444–149463, 2019.
- [11] T. D. Nguyen *et al.*, “DIoT: A Federated Self-learning Anomaly Detection System for IoT,” in *Proc. IEEE ICDSCS*, 2019, pp. 756–767.
- [12] E. Vasilomanolakis, S. Karuppayah, M. Mühlhäuser, and M. Fischer, “Taxonomy and Survey of Collaborative Intrusion Detection,” *ACM Comput. Surv.*, vol. 47, no. 4, Art. 55, 2015.
- [13] A. Feraudo, P. Yadav, V. Safronov, D. A. Popescu, R. Mortier, S. Wang, P. Bellavista, and J. Crowcroft, “CoLearn: Enabling Federated Learning in MUD-Compliant IoT Edge Networks,” in *Proc. ACM EdgeSys*, 2020, pp. 25–30.
- [14] L. Morgese Zangrandi, T. van Ede, T. Booijs, S. Sciancalepore, L. Allodi, and A. Continella, “Stepping out of the MUD: Contextual Threat Information for IoT Devices with Manufacturer-Provided Behavior Profiles,” in *Proc. ACSAC*, 2022, pp. 467–480.
- [15] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, “MISP: The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform,” in *Proc. ACM WISCS*, 2016, pp. 49–56.
- [16] OASIS CTI TC, “STIX Version 2.1,” OASIS Standard, Jun. 2021.
- [17] S. D. Kamvar, M. T. Schlosser, and H. Garcia-Molina, “The EigenTrust Algorithm for Reputation Management in P2P Networks,” in *Proc. WWW*, 2003.
- [18] A. Jøsang, R. Ismail, and C. Boyd, “A Survey of Trust and Reputation Systems for Online Service Provision,” *Decision Support Systems*, vol. 43, no. 2, pp. 618–644, 2007.
- [19] M. Sloman, “Policy Driven Management for Distributed Systems,” *J. Netw. Syst. Manage.*, vol. 2, no. 4, pp. 333–360, 1994.
- [20] A. Clemm, L. Ciavaglia, L. Z. Granville, and J. Tantsura, “Intent-Based Networking: Concepts and Definitions,” RFC 9315, IETF, Oct. 2022.
- [21] E. Al-Shaer and H. Hamed, “Modeling and Management of Firewall Policies,” *IEEE Trans. Netw. Serv. Manage.*, vol. 1, no. 1, pp. 2–10, Apr. 2004, doi: 10.1109/TNSM.2004.4623689.
- [22] A. Chowdhary, A. Sabur, N. Vadnere, and D. Huang, “Intent-Driven Security Policy Management for Software-Defined Systems,” *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 4, pp. 5208–5223, 2022, doi: 10.1109/TNSM.2022.3183591.
- [23] A. dos Santos Pires, F. M. Matos, A. Santos, D. Pessoa, *et al.*, “PipeConf: An Integrated Architecture for the Automated Configuration of Network Assets,” *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 3, Sep. 2022, doi: 10.1109/TNSM.2022.3195382.
- [24] A. Vergütz, B. V. dos Santos, B. Kantarci, and M. Nogueira, “Data Instrumentation From IoT Network Traffic as Support for Security Management,” *IEEE Trans. Netw. Serv. Manage.*, vol. 20, no. 2, pp. 1392–1404, Jun. 2023, doi: 10.1109/TNSM.2022.3233673.
- [25] C. K. Rath, A. K. Mandal, and A. Sarkar, “Blockchain-based Dynamic MUD Profiles for Tamper-proof IoT Access Control,” *J. Inf. Secur. Appl.*, vol. 95, Art. 104273, 2025, doi: 10.1016/j.jisa.2025.104273.
- [26] J. Ren, D. J. Dubois, D. Choffnes, A. M. Mandalari, R. Kolcun, and H. Haddadi, “Information Exposure From Consumer IoT Devices: A Multidimensional, Network-Informed Measurement Approach,” in *Proc. ACM IMC*, 2019, pp. 267–279, doi: 10.1145/3355369.3355577.
- [27] O. Alrawi, C. Lever, M. Antonakakis, and F. Monrose, “SoK: Security Evaluation of Home-Based IoT Deployments,” in *Proc. IEEE Symp. Security and Privacy*, 2019.
- [28] D. Y. Huang, N. Aphorpe, F. Li, G. Acar, and N. Feamster, “IoT Inspector: Crowdsourcing Labeled Network Traffic from Smart Home Devices at Scale,” *Proc. ACM Interact. Mob. Wearable Ubiquitous Technol.*, vol. 4, no. 2, Art. 46, 2020.
- [29] W. He, K. Bryson, R. Calderon, V. Prakash, N. Feamster, D. Y. Huang, and B. Ur, “Can Allowlists Capture the Variability of Home IoT Device Network Behavior?” in *Proc. IEEE EuroS&P*, 2024, pp. 114–138, doi: 10.1109/EuroSP60621.2024.00015.
- [30] T. Reddy, K. D. Wing, and B. Anderson, “Manufacturer Usage Description (MUD) for TLS and DTLS Profiles for IoT Devices,” RFC 9761, IETF, Apr. 2025.
- [31] A. Lotto, S. Sciancalepore, A. Brighente, and M. Conti, “FIDEM: A Standard-Compliant Framework for Secure Binding of MUD Profiles to IoT Devices,” *arXiv preprint arXiv:2605.29654*, May 2026.
- [32] A. Zhang, X. Lee, Z. Zhuang, J. Wei, Y. Fu, and B. Peng, “POLARIS: Cross-Domain Access Control via Verifiable Identity and Policy-Based Authorization,” in *Proc. IEEE 24th Int. Conf. Trust, Security and Privacy in Computing and Communications (TrustCom)*, 2025, pp. 1489–1498.
- [33] R. Pang *et al.*, “Zanzibar: Google’s Consistent, Global Authorization System,” in *Proc. USENIX Annu. Tech. Conf. (ATC)*, 2019, pp. 33–46.
- [34] M. Richardson, W. Pan, and E. Lear, “Authorized Update to MUD URLs,” IETF Internet-Draft draft-ietf-iotops-mud-acceptable-urls, work in progress, 2025.
- [35] OASIS, “eXtensible Access Control Markup Language (XACML) Version 3.0,” OASIS Standard, Jan. 2013.
- [36] N. Damianou, N. Dulay, E. Lupu, and M. Sloman, “The Ponder Policy Specification Language,” in *Proc. IEEE Int. Workshop on Policies for Distributed Systems and Networks (POLICY)*, 2001, pp. 18–38.
- [37] M. Shapiro, N. Preguica, C. Baquero, and M. Zawirski, “Conflict-Free Replicated Data Types,” in *Proc. Int. Symp. Stabilization, Safety, and Security of Distributed Systems (SSS)*, 2011, pp. 386–400.
- [38] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS Encrypted Client Hello,” RFC 9849, IETF, Mar. 2026.
- [39] M. Thomson and S. Turner, “Using TLS to Secure QUIC,” RFC 9001, IETF, May 2021.

Author One received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].

Author Two received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].

Author Three received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].

Author Four received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Five received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Six received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].



Author Seven received the Ph.D. degree in [field] from [university] in [year]. [He/She/They] is currently [position] at [institution]. Research interests include [topic one], [topic two], and [topic three].